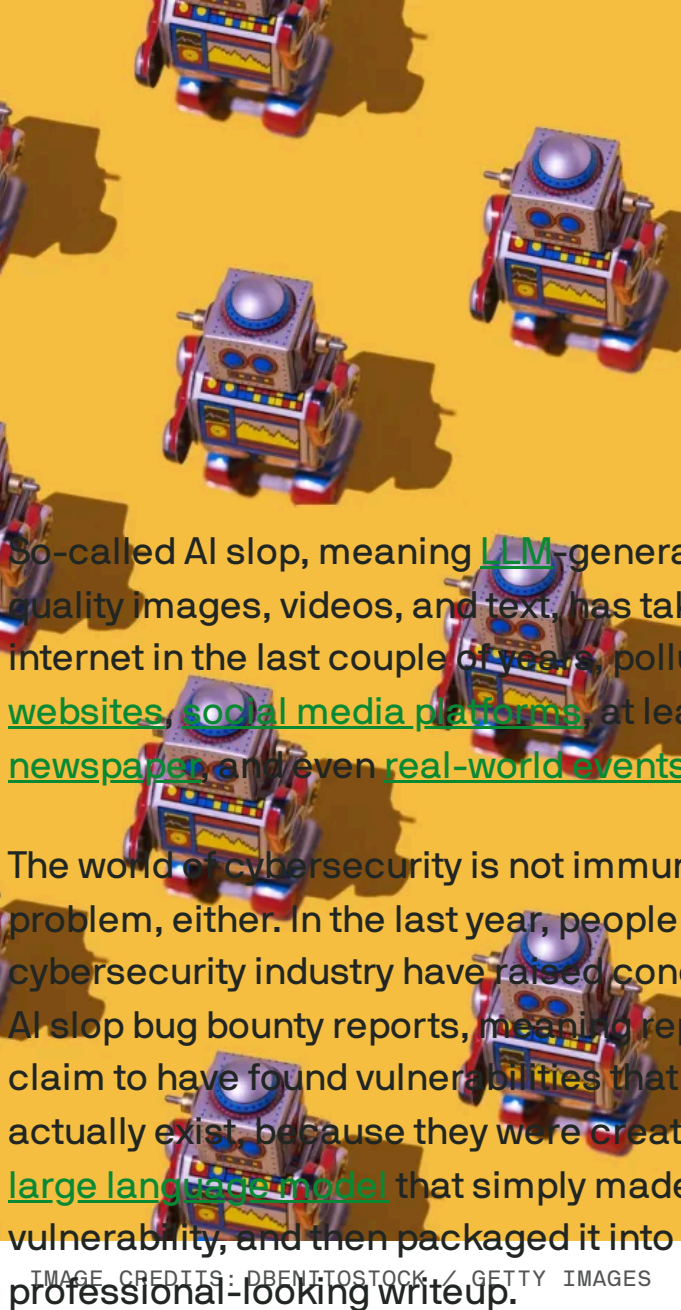


Advertisement

SECURITY



AI slop and fake reports
are coming for your bug
bounty programs



Lorenzo Franceschi-
Bicchierai

— 8:00 AM PDT · July 24,
2025

So-called AI slop, meaning [LLM](#)-generated low-quality images, videos, and text, has taken over the internet in the last couple of years, polluting [websites](#), [social media platforms](#), at least [one newspaper](#), and even [real-world events](#).

The world of cybersecurity is not immune to this problem, either. In the last year, people across the cybersecurity industry have raised concerns about AI slop bug bounty reports, meaning reports that claim to have found vulnerabilities that do not actually exist, because they were created with a [large language model](#) that simply made up the vulnerability, and then packaged it into a professional-looking writeup.

IMAGE CREDITS: DBENT/ISTOCK / GETTY IMAGES

“People are receiving reports that sound reasonable, they look technically correct. And then you end up digging into them, trying to figure out, ‘oh no, where is this vulnerability?’,” Vlad Ionescu, the co-founder and CTO of [RunSybil](#), a startup that develops AI-powered bug hunters, told TechCrunch.

“It turns out it was just a hallucination all along. The technical details were just made up by the LLM,” said Ionescu.

Ionescu, who used to work at Meta’s red team tasked with hacking the company from the inside, explained that one of the issues is that LLMs are designed to be helpful and give positive responses.

DISRUPT

October 27-29, 2025 | San Francisco

Put your brand in front of 10,000+ tech and VC leaders across all three days of Disrupt 2025. Amplify your reach, spark real connections, and lead the innovation charge. Secure your exhibit space before your competitor does.

[Book Your Table >](#)

Most Popular



- Key sections of the US Constitution deleted from government’s website
- Three weeks after acquiring Windsurf, Cognition offers staff the exit door
- Roku launches Howdy, a \$2.99 ad-free streaming service
- Spotify raises subscription prices
- The uproar over Vogue’s AI-generated ad isn’t just about fashion

“If you ask it for a report, it’s going to give you a report. And then people will copy and paste these into the bug bounty platforms and overwhelm the platforms themselves, overwhelm the customers, and you get into this frustrating situation,” said Ionescu.

“That’s the problem people are running into, is we’re getting a lot of stuff that looks like gold, but it’s actually just crap,” said Ionescu.

Just in the last year, there have been real-world examples of this. Harry Sintonen, a security researcher, revealed that the open source security project Curl received a fake report. “The attacker miscalculated badly,” Sintonen wrote [in a post on Mastodon](#). “Curl can smell AI slop from miles away.”

In response to Sintonen’s post, Benjamin Piouffle of Open Collective, a tech platform for nonprofits, [said](#) that they have the same problem: that their inbox is “flooded with AI garbage.”

One open source developer, who maintains the CycloneDX project on GitHub, [pulled their bug bounty down entirely](#) earlier this year after receiving “almost entirely AI slop reports.”

The leading bug bounty platforms, which essentially work as intermediaries between bug bounty hackers and companies who are willing to pay and reward them for finding flaws in their products and software, are also seeing a spike in AI-generated reports, TechCrunch has learned.

- Your public ChatGPT queries are getting indexed by Google and other search engines
- The best dating apps aren’t even dating apps

Contact Us

Do you have more information about how AI is impacting the cybersecurity industry? We’d love to hear from you. From a non-work device and network, you

can contact Lorenzo Franceschi-Bicchierai securely on Signal at +1 917 257 1382, or via Telegram and Keybase @lorenzofb, or [email](#).

Michiel Prins, the co-founder and senior director of product management at HackerOne, told TechCrunch that the company has encountered some AI slop.

“We’ve also seen a rise in false positives — vulnerabilities that appear real but are generated by LLMs and lack real-world impact,” said Prins. “These low-signal submissions can create noise that undermines the efficiency of security programs.”

Prins added that reports that contain “hallucinated vulnerabilities, vague technical content, or other forms of low-effort noise are treated as spam.”

Casey Ellis, the founder of Bugcrowd, said that there are definitely researchers who use AI to find bugs and write the reports that they then submit to the company. Ellis said they are seeing an overall increase of 500 submissions per week.

“AI is widely used in most submissions, but it hasn’t yet caused a significant spike in low-quality ‘slop’ reports,” Ellis told TechCrunch. “This’ll probably escalate in the future, but it’s not here yet.”

Ellis said that the Bugcrowd team that analyzes submissions reviews the reports manually using established playbooks and workflows, as well as with machine learning and AI “assistance.”

To see if other companies, including those that run their own bug bounty programs, are also receiving an increase in invalid reports or reports containing non-existent vulnerabilities hallucinated by LLMs,

TechCrunch contacted Google, Meta, Microsoft, and Mozilla.

Damiano DeMonte, a spokesperson for Mozilla, which develops the Firefox browser, said that the company has “not seen a substantial increase in invalid or low-quality bug reports that would appear to be AI-generated,” and the rejection rate of reports — meaning how many reports get flagged as invalid — has remained steady at five or six reports per month, or less than 10% of all monthly reports.

Mozilla’s employees who review bug reports for Firefox don’t use AI to filter reports, as it would likely be difficult to do so without the risk of rejecting a legitimate bug report,” DeMonte said in an email.

Microsoft and Meta, companies that have both bet heavily on AI, declined to comment. Google did not respond to a request for comment.

Ionescu predicts that one of the solutions to the problem of rising AI slop will be to keep investing in AI-powered systems that can at least perform a preliminary review and filter submissions for accuracy.

In fact, on Tuesday, HackerOne [launched](#) Hai Triage, a new triaging system that combines humans and AI. According to HackerOne, this new system is leveraging “AI security agents to cut through noise, flag duplicates, and prioritize real threats.” Human analysts then step in to validate the bug reports and escalate as needed.

As hackers increasingly use LLMs and companies rely on AI to triage those reports, it remains to be seen which of the two AIs will prevail.

Topics: [AI](#) [AI](#) [ai slop](#) [bug bounty](#)

[Bug bounty programs](#) [Bugcrowd](#)

[cybersecurity](#) [Google](#) [HackerOne](#) [hackers](#)

[hacking](#) [Meta](#) [Microsoft](#) [Mozilla](#) [Security](#)

[f](#) [X](#) [in](#) [reddit](#) [email](#) [link](#)



Lorenzo Franceschi-Bicchierai

Senior Reporter, Cybersecurity | [X](#) [reddit](#) [m](#)

Lorenzo Franceschi-Bicchierai is a Senior Writer at TechCrunch, where he covers hacking, cybersecurity,...

[View Bio](#) >

KEEP READING

SECURITY

[f](#) [X](#) [in](#) [reddit](#) [email](#) [link](#)

Google says its AI-based bug hunter found 20 security vulnerabilities

Latest

Security

Startups

AI



Events

Podcasts

Newsletters

in various popular open source software.

Adkins said that Big Sleep, which is developed by the company's AI department DeepMind as well as its elite team of hackers Project Zero, [reported its first-ever vulnerabilities](#), mostly in open source software such as audio and video library FFmpeg and image-editing suite ImageMagick.

Given that the vulnerabilities are not fixed yet, we don't have details of their impact or severity, as Google [does not yet want to provide details](#), which is a standard policy when waiting for bugs to be fixed. But the simple fact that Big Sleep found these vulnerabilities is significant, as it shows these tools are starting to get real results, even if there was a human involved in this case.

"To ensure high quality and actionable reports, we have a human expert in the loop before reporting, but each vulnerability was found and reproduced by the AI agent without human intervention," Google's spokesperson Kimberly Samra told TechCrunch.

Royal Hansen, Google's vice president of engineering, [wrote on X](#) that the findings demonstrate "a new frontier in automated vulnerability discovery."

Subscribe for the industry's biggest tech news

TechCrunch Daily News



Every weekday and Sunday, you can get the best of TechCrunch's coverage.

Startups Weekly



Startups are the core of TechCrunch, so get our best coverage delivered weekly.

TechCrunch Week in Review



Get the best of our coverage, delivered to your inbox every Saturday.

TechCrunch Mobility



TechCrunch Mobility is your destination for transportation news and insight.

No newsletters selected.

Subscribe

By submitting your email, you agree to our [Terms](#) and [Privacy Notice](#).

LLM-powered tools that can look for and find vulnerabilities [are already a reality](#). Other than Big Sleep, there's [RunSybil](#) and XBOW, among others.

TC

Techcrunch event

Tech and VC heavyweights join the Disrupt 2025 agenda

Netflix, ElevenLabs, Wayve, Sequoia Capital — just a few of the heavy hitters joining the Disrupt 2025 agenda. They're here to deliver the insights that fuel startup growth and sharpen your edge. Don't miss the 20th anniversary of TechCrunch Disrupt, and a chance to learn from the top voices in tech — grab your ticket now and save up to \$675 before prices rise on August 7.

Tech and VC heavyweights join the Disrupt 2025 agenda

Netflix, ElevenLabs, Wayve, Sequoia Capital — just a few of the heavy hitters joining the Disrupt 2025 agenda. They're here to deliver the insights that fuel startup growth and sharpen your edge. Don't miss the 20th anniversary of TechCrunch Disrupt, and a chance to learn from the top voices in tech — grab your ticket now and save up to \$675 before prices rise.

San Francisco | October 27-29, 2025

REGISTER NOW

XBOW has garnered headlines after [it reached the top](#) of one of the U.S. leaderboards at bug bounty platform HackerOne. It's important to note that in most cases, these reports have a human at some point of the process to verify that the AI-powered

bug hunter found a legitimate vulnerability, as is the case with Big Sleep.

Vlad Ionescu, co-founder and chief technology officer at RunSybil, a startup that develops AI-powered bug hunters, told TechCrunch that Big Sleep is a “legit” project, given that it has “good design, people behind it know what they’re doing, Project Zero has the bug finding experience and DeepMind has the firepower and tokens to throw at it.”

There is obviously a lot of promise with these tools, but also significant downsides. Several people who maintain different software projects have complained of [bug reports that are actually hallucinations](#), with some calling them the bug bounty equivalent of AI slop.

“That’s the problem people are running into, is we’re getting a lot of stuff that looks like gold, but it’s actually just crap,” Ionescu previously told TechCrunch.

Topics: [AI](#) [Big Sleep](#) [cybersecurity](#) [DeepMind](#)

[Google](#) [hackers](#) [infosec](#) [LLMs](#) [Security](#)

[f](#) [X](#) [in](#) [t](#) [✉](#) [🔗](#)



Lorenzo Franceschi-Bicchierai

Senior Reporter, Cybersecurity | [X](#) [🦋](#) [m](#)

Lorenzo Franceschi-Bicchierai is a Senior Writer at TechCrunch, where he covers hacking, cybersecurity,...

[View Bio](#) >



IMAGE CREDITS: BRYCE DURBIN / TECHCRUNCH

SECURITY



Facebook awards researcher \$100,000 for finding bug that granted internal access

Lorenzo Franceschi-Bicchierai

— 9:48 AM PST · January 9, 2025

In October 2024, security researcher [Ben Sadeghipour](#) was analyzing Facebook’s ad platform when he found a security vulnerability that allowed him to run commands on the internal Facebook server housing that platform, essentially giving him control of the server.

After he reported the vulnerability to Facebook’s owner Meta, which Sadeghipour said took just one hour to fix it, the social networking giant awarded him \$100,000 in a bug bounty payout.

“My assumption is that it’s something you may want to fix because it is directly inside of your

Advertisement

Latest in Security

infrastructure,” Sadeghipour wrote in the report he sent to Meta, he told TechCrunch. Meta responded to his report, telling Sadeghipour to “refrain from testing any further” while they fix the vulnerability.

The issue, according to Sadeghipour, was that one of the servers that Facebook used for creating and delivering ads was vulnerable to a previously fixed flaw found in the Chrome browser, which Facebook uses in its ads system. Sadeghipour said this unpatched bug allowed him to hijack it using a headless Chrome browser (essentially a version of the browser that users run from the computer’s terminal) to interact directly with Facebook’s internal servers.

Sadeghipour, who found the Facebook vulnerability working with independent researcher Alex Chapman, told TechCrunch that online advertising platforms make for juicy targets because, “there’s so much that happens in the background of making these ‘ads’ — whether they are video, text, or images.”

“But at the core of it all it’s a bunch of data being processed on the server-side and it opens up the door for a ton of vulnerabilities,” said Sadeghipour.

The researcher said he didn’t test out everything he could have done once inside the Facebook server, but “what makes this dangerous is this was probably a part of an internal infrastructure.”

TC

Techcrunch event

Tech and VC heavyweights join the Disrupt 2025 agenda

Netflix, ElevenLabs, Wayve, Sequoia Capital — just a few of the heavy hitters joining the Disrupt 2025 agenda. They’re here to deliver the insights that fuel startup growth and

See More

SECURITY



A rival Tea app for men is leaking its users’ personal data and driver’s licenses

Amanda Silberling,
Zack Whittaker

- 12 hours ago

SECURITY



Citizen Lab director warns cyber industry about US authoritarian descent

Lorenzo Franceschi-
Bicchierai

- 17 hours ago

TECHCRUNCH DISRUPT 2025



Final call: TechCrunch Disrupt 2025 ticket savings end tonight

TechCrunch Events
- 19 hours ago

Advertisement

sharpen your edge. Don't miss the 20th anniversary of TechCrunch Disrupt, and a chance to learn from the top voices in tech — grab your ticket now and save up to \$675 before prices rise on August 7.

Tech and VC heavyweights join the Disrupt 2025 agenda

Netflix, ElevenLabs, Wayve, Sequoia Capital — just a few of the heavy hitters joining the Disrupt 2025 agenda. They're here to deliver the insights that fuel startup growth and sharpen your edge. Don't miss the 20th anniversary of TechCrunch Disrupt, and a chance to learn from the top voices in tech — grab your ticket now and save up to \$675 before prices rise.

San Francisco | October 27-29, 2025

REGISTER NOW

“Since we have code execution, we could’ve interacted with any of the sites within that infrastructure,” said Sadeghipour. “With an [[remote code execution](#) vulnerability], you can bypass some of these limitations and also directly pull stuff from the server itself and the other machines that it has access to.”

Meta spokesperson Nicole Catalano acknowledged receipt of TechCrunch’s request for comment, but did not comment by press time.

Sadeghipour also said that similar ad platforms that other companies run, and which he has been analyzing, are vulnerable to similar vulnerabilities.

Topics: [Ads](#) [bug bounty](#) [bugs](#) [cybersecurity](#)

[Exclusive](#) [Facebook](#) [hacking](#) [infosec](#)

[Meta](#) [Security](#) [security vulnerability](#)

Advertisement



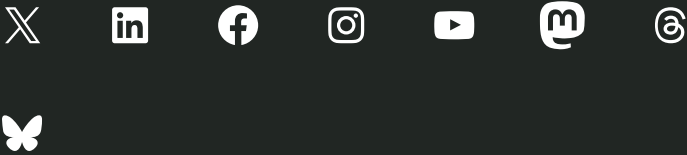
Lorenzo Franceschi-Bicchierai

Senior Reporter, Cybersecurity |

Lorenzo Franceschi-Bicchierai is a Senior Writer at TechCrunch, where he covers hacking, cybersecurity,...

[View Bio](#) >

Loading the next article



[TechCrunch Staff](#)

[Contact Us](#)

[Advertise](#)

[Crunchboard Jobs](#)

[Site Map](#)

[Terms of Service](#)

[Privacy Policy](#)

[RSS Terms of Use](#)

[OpenAI](#)
[Perplexity](#)
[Cisco](#)
[DeepMind](#)
[Windsurf](#)
[Tech Layoffs](#)
[ChatGPT](#)